INSTRUKTIONSMANUAL FÖR BRF-STYRELSEN

GDPR

i bostadsrätts-föreningen

Instruktionsmanual för BRF-styrelsen

11	10	4
avsnitt	tips till styrelsen	checklistor

© 2025 Styrelsekörkortet · styrelsekorkortet.se

INSTRUKTIONSMANUAL FÖR BRF-STYRELSEN

GDPR i bostadsrättsföreningen

Vad lagen kräver, hur ni agerar och vad ni aldrig får glömma.

Det här lär du dig

- ✓ Förstå vad GDPR innebär för er BRF
- ✓ Veta vilka personuppgifter ni hanterar
- ✓ Upprätta en korrekt registerförteckning
- ✓ Veta när och hur uppgifter ska rensas
- ✓ Känna till medlemmarnas rättigheter
- ✓ Hantera incidenter och avvikelser rätt
- ✓ Följa de 10 praktiska styrelsetipsen
- ✓ Bocka av checklistorna och vara redo

INNEHÅLL

01 Vad är GDPR – och gäller det oss?
02 Vilka personuppgifter hanterar en BRF?
03 De sex grundprinciperna
04 Rättslig grund – varför får vi behandla uppgifter?
05 Personuppgiftsansvarig & dataskyddsombud
06 Registerförteckning – vad och hur
07 Rensning & gallring – en praktisk guide
08 Medlemmarnas rättigheter
09 Säkerhet & incidenter
10 10 GDPR-tips till styrelsen
11 Checklista – använd direkt

© 2025 Styrelsekörkortet

AVSNITT 01–03

Vad är GDPR – och de sex grundprinciperna

Vad är GDPR?

GDPR – General Data Protection Regulation, på svenska dataskyddsförordningen – är en EU-lag som trädde i kraft den 25 maj 2018. Den gäller alla organisationer som behandlar personuppgifter om personer i EU, inklusive bostadsrättsföreningar. Lagen ersatte den tidigare PuL (personuppgiftslagen).

En bostadsrättsförening är en ekonomisk förening som behandlar personuppgifter om sina medlemmar, styrelseledamöter, anställda och i vissa fall även hyresgäster. Det innebär att GDPR gäller er – oavsett hur liten föreningen är.

SANKTIONER

Datainspektionen (IMY) kan utfärda sanktionsavgifter vid överträdelser. För mindre organisationer som BRF:er är avgifterna normalt lägre, men kränkningar av enskildas integritet kan leda till skadeståndskrav. Rätt hantering skyddar både föreningen och dess ledamöter.

De sex grundprinciperna – GDPR:s kärna

All behandling av personuppgifter måste följa sex grundprinciper. Som styrelse är ni ansvariga för att dessa följs.

1. **Laglighet, korrekthet & öppenhet**
   Uppgifter får bara behandlas om det finns en laglig grund. Behandlingen ska vara korrekt och transparent mot de registrerade.
2. **Ändamålsbegränsning**
   Uppgifter får bara samlas in för specifika, uttryckliga och legitima ändamål. De får inte senare behandlas på ett sätt som är oförenligt med dessa ändamål.
3. **Uppgiftsminimering**
   Bara de uppgifter som faktiskt behövs för ändamålet får samlas in. Inte mer "för säkerhets skull".
4. **Riktighet**
   Personuppgifter ska vara korrekta och hållas aktuella. Felaktiga uppgifter ska rättas eller raderas utan dröjsmål.
5. **Lagringsminimering**
   Uppgifter får inte sparas längre än nödvändigt. Ni behöver ha rutiner för när uppgifter ska raderas.
6. **Integritet & konfidentialitet**
   Lämpliga tekniska och organisatoriska åtgärder ska vidtas för att skydda uppgifterna mot obehörig åtkomst, förlust eller förstöring.

© 2025 Styrelsekörkortet

AVSNITT 02 & 04

Vilka uppgifter hanterar ni och på vilken rättslig grund?

Personuppgifter i en BRF – översikt

Nedan är en översikt över de vanligaste kategorierna av personuppgifter i en bostadsrättsförening, hur länge de bör sparas och när de ska gallras.

KATEGORI	EXEMPEL PÅ UPPGIFTER	LAGRING	RENSNING
Medlemmar	Namn, adress, personnummer, lägenhetsnummer, insats, e-post, telefon	Under hela medlemskapet. Medlems- och lägenhetsförteckning bevaras.	Medlems- och lägenhetsförteckning bevaras (lagstadgad handling enligt BRL). Övriga uppgifter som kopior och mejl gallras när de inte längre behövs. Bokföringsuppgifter sparas 7 år.
Styrelseledamöter	Namn, personnummer, adress, roll, mandatperiod	Under uppdraget + 10 år	Gallras 10 år efter uppdragets slut (ansvarsfrihet och protokoll).
Mötesprotokoll	Namn på deltagare, röster, beslut	Minst 10 år	Gallras efter 10 år. Viktiga beslut kan behöva sparas längre.
Anställda / entreprenörer	Namn, personnummer, löneuppgifter, avtal	Under anställningen + 7 år	Löneunderlag sparas 7 år. Övriga handlingar gallras när de inte längre behövs.
Hyresgäster	Namn, adress, hyresavtal, betalningshistorik	Under hyrestiden + 3 år	Gallras 3 år efter avtalets slut om inga tvister finns.
Felparkerare / störningar	Namn, bilregisternummer, händelsebeskrivning	Tills ärendet är avslutat	Gallras direkt när ärendet är avslutat och inga rättsliga krav finns.

© 2025 Styrelsekörkortet

Rättslig grund – varför får ni behandla uppgifterna?

Ni måste alltid ha en rättslig grund för att behandla personuppgifter. Dessa fyra är de vanligaste för en BRF:

Avtal

Behandling är nödvändig för att fullgöra ett avtal med den registrerade – t.ex. bostadsrättsavtalet eller hyresavtalet.

Exempel: Medlemsregister, hyresavtal, arvode till styrelseledamöter.

Rättslig förpliktelse

Behandling krävs enligt lag – t.ex. bokföringslagen, bostadsrättslagen eller skattelagstiftning.

Exempel: Bokföring, löneunderlag, skatteuppgifter, årsredovisning.

Berättigat intresse

Föreningens legitima intresse väger tyngre än den registrerades intresse – men kräver en intresseavvägning.

Exempel: Kameraövervakning av entrén, hantering av störningsärenden.

Samtycke

Den registrerade har lämnat ett uttryckligt, frivilligt och informerat samtycke.

Exempel: Nyhetsbrev, marknadsföring, frivilliga fotoregister. Samtycke kan alltid återkallas.

VIKTIGT OM SAMTYCKE

Samtycke är ofta den sämsta rättsliga grunden – den kan alltid återkallas. Välj avtal eller rättslig förpliktelse när det är möjligt. Samtycke är lämpligt för frivilliga ändamål som nyhetsbrev.

© 2025 Styrelsekörkortet

AVSNITT 05–06

Personuppgiftsansvarig och registerförteckning

Vem är personuppgiftsansvarig?

Bostadsrättsföreningen som juridisk person är personuppgiftsansvarig – inte enskilda styrelseledamöter. Det är **styrelsen kollektivt** som ansvarar för att GDPR följs. I praktiken bör en person i styrelsen utses som ansvarig för det löpande GDPR-arbetet.

BEHÖVER VI ETT DATASKYDDSOMBUD (DSO)?

Dataskyddsombud är obligatoriskt för myndigheter och organisationer som i stor skala behandlar känsliga personuppgifter. För de flesta BRF:er är det inte ett lagkrav – men det är god praxis att utse en GDPR-ansvarig i styrelsen som håller sig uppdaterad och ansvarar för att rutiner följs.

Registerförteckning – ni måste ha en

Alla organisationer som behandlar personuppgifter ska enligt GDPR föra ett register över sina behandlingsaktiviteter (artikel 30). Det behöver inte vara avancerat – ett enkelt dokument räcker.

Registerförteckningen ska innehålla sju delar:

01 Ändamål med behandlingen
Beskriv varför ni behandlar uppgifterna. T.ex. "Hantera medlemsregister och säkerställa korrekt förvaltning av bostadsrättsföreningen."

02 Kategorier av registrerade
Vilka personerna är – t.ex. medlemmar, styrelseledamöter, hyresgäster, anställda.

03 Kategorier av personuppgifter
Vilka uppgifter ni behandlar – t.ex. namn, adress, personnummer, e-post, betalningshistorik.

04 Rättslig grund
Varför ni har rätt att behandla uppgifterna – avtal, rättslig förpliktelse, berättigat intresse eller samtycke.

05 Lagringsperiod
Hur länge uppgifterna sparas. Om ni inte vet exakt, ange kriterier för när de gallras.

06 Mottagare / tredje part
Om uppgifterna delas med t.ex. förvaltare, revisorer, banker eller myndigheter – specificera vem och varför.

07 Tekniska skyddsåtgärder
Hur uppgifterna skyddas – lösenordsskydd, kryptering, begränsad åtkomst, säkerhetskopiering.

© 2025 Styrelsekörkortet

AVSNITT 07

Rensning & gallring – en praktisk guide

GDPR kräver att personuppgifter inte sparas längre än nödvändigt – principen om lagringsminimering. Nedan är en praktisk guide för de vanligaste situationerna i en BRF.

Medlemmen säljer sin lägenhet

När: När överlåtelsen är registrerad och alla ekonomiska mellanhavanden avklarade.

Vad: Grunduppgifter i medlemsregistret. Bokföringsunderlag sparas 7 år. Protokoll sparas 10 år. Kontaktuppgifter raderas direkt.

Hyresavtal löper ut

När: 3 år efter avtalets slut (preskriptionstid för hyresfordringar).

Vad: Hyresavtal, betalningshistorik, kontaktuppgifter. Ekonomiska handlingar sparas enligt bokföringslagen.

Styrelseledamot avgår

När: Direkt för känsliga personuppgifter. Protokoll och beslutsunderlag sparas 10 år.

Vad: Personnummer och privata kontaktuppgifter raderas direkt. Namn i protokoll sparas. Fullmakter och attesträtt återkallas omedelbart.

Anställd slutar

När: 7 år för löneunderlag och anställningsavtal (bokföringslagen och skattelagen).

Vad: Lönespecifikationer, anställningsavtal, sjukfrånvaro. Personliga referenser och ansökningshandlingar raderas direkt efter anställning.

Störningsärende avslutat

När: När ärendet är avslutat och inga rättsliga anspråk kan förväntas.

Vad: Namn, kontaktuppgifter och händelsebeskrivning. Spara bara om rättsprocess pågår.

Kameraövervakning

När: Max 72 timmar om inget incident inträffat. Längre vid polisanmälan.

Vad: Alla inspelningar raderas automatiskt. Säkerställ att systemet är rätt inställt.

ÅRSRUTIN – GRÄV IGENOM ERA REGISTER EN GÅNG PER ÅR

Lägg in en punkt på styrelsens januarimöte: gå igenom alla register och datalagringspunkter. Vilka uppgifter är föråldrade? Vilka behövs inte längre? Rensa, dokumentera och uppdatera er registerförteckning. Det tar en timme och håller er compliant.

© 2025 Styrelsekörkortet

AVSNITT 08–09

Medlemmarnas rättigheter och säkerhet & incidenter

Sex rättigheter ni måste känna till

Rätt till information

Den registrerade har rätt att veta att ni behandlar deras uppgifter, varför, hur länge och vem som är ansvarig. Informera i samband med inträde i föreningen.

→ **Gör så här:** Skicka en kort integritetspolicy till nya medlemmar. Publicera den på er webbplats.

Rätt till tillgång

Varje person har rätt att begära ett registerutdrag – en kopia på alla uppgifter ni har om dem.

→ **Gör så här:** Svara inom 1 månad. Använd IMY:s mall för registerutdrag. Identifiera personen innan ni skickar.

Rätt till rättelse

Om uppgifter är felaktiga ska de rättas utan dröjsmål.

→ **Gör så här:** Ha en rutin för hur ni tar emot och hanterar rättelseönskemål. Bekräfta alltid skriftligt.

Rätt till radering

Den registrerade kan begära att uppgifter raderas – "rätten att bli glömd". Gäller inte om ni har en rättslig skyldighet att spara.

→ **Gör så här:** Bedöm om rättslig grund finns att neka. Dokumentera alltid ert beslut och motivera det.

Rätt till begränsning

Behandlingen kan begränsas medan en tvist om riktigheten pågår.

→ **Gör så här:** Märk uppgifterna som begränsade i ert system. Behandla dem inte tills tvisten är löst.

Rätt att invända

Den registrerade kan invända mot behandling baserad på berättigat intresse.

→ **Gör så här:** Bedöm om föreningens intresse väger tyngre. Dokumentera avvägningen.

Säkerhet – fyra grundkrav

01 **Begränsa åtkomsten**
Bara de i styrelsen som behöver uppgifterna för sitt uppdrag ska ha tillgång till dem. Inget delat lösenord till förvaltarens system.

02 **Starka lösenord & tvåfaktorsinloggning**
Alla system med personuppgifter ska skyddas med starka, unika lösenord och gärna tvåfaktorsautentisering.

03 **Kryptering av e-post vid känslig data**
Skicka aldrig personnummer, löneuppgifter eller känsliga uppgifter i okrypterad e-post. Använd säker filöverföring

© 2025 Styrelsekörkortet

04

Säkerhetskopior

Säkerhetskopiera era register regelbundet och lagra backupen på en säker, separat plats – inte bara på en ensk dators skrivbord.

PERSONUPPGIFTSINCIDENT – SÅ AGERAR NI

Om personuppgifter läcker ut, förstörs eller hamnar i fel händer har ni 72 timmar på er att anmäla det till IMY – om incidenten innebär en risk för de registrerade. Dokumentera alltid incidenten, vad som hände, vilka uppgifter som berördes och vad ni gjort för att begränsa skadan. Anmälan görs på imy.se.

© 2025 Styrelsekörkortet

AVSNITT 10

10 GDPR-tips till styrelsen

Tio konkreta åtgärder som gör er GDPR-hantering enkel, strukturerad och hållbar över tid.

1 Utse en GDPR-ansvarig i styrelsen

En person i styrelsen bör ha ett utpekat ansvar för GDPR-arbetet. Inte ensam ansvarig – men sammanhållande och uppdaterad.

2 Upprätta en registerförteckning – och håll den aktuell

Börja med IMY:s mall. Uppdatera den varje gång ni börjar behandla uppgifter på ett nytt sätt eller slutar med ett gammalt.

3 Skriv en enkel integritetspolicy

Informera medlemmar om hur ni behandlar deras uppgifter. En sida räcker – publicera den på er webbplats och skicka till nya medlemmar.

4 Gallra regelbundet – årsrutin i januari

Boka in en timme varje januari för att gå igenom register och radera uppgifter som inte längre behövs. Dokumentera vad som gallrats.

5 Kryptera känslig e-post

Personnummer och ekonomisk information ska aldrig skickas i klartext via mejl. Använd krypterad filöverföring eller säker portal.

6 Kontrollera era leverantörer

Förvaltare, revisorer och andra som behandlar personuppgifter åt er måste ha ett personuppgiftsbiträdesavtal (PUB-avtal). Kontrollera att ni har ett.

7 Begränsa åtkomsten till systemen

Bara de styrelseledamöter som faktiskt behöver uppgifterna ska ha tillgång till dem. Återkalla åtkomst direkt när någon lämnar styrelsen.

8 Ha en plan för incidenter

Bestäm i förväg: Vem kontaktas om något läcker? Hur dokumenterar ni? IMY ska kontaktas inom 72 timmar. Ha mallen klar innan det händer.

9 Hämta inte in fler uppgifter än ni behöver

GDPR:s princip om uppgiftsminimering. Behöver ni verkligen personnummer på alla? Samla bara in det ni faktiskt ska använda.

10 Håll er uppdaterade – GDPR är inte statisk

IMY publicerar löpande vägledning och avgöranden. Prenumerera på IMY:s nyhetsbrev och se till att styrelsen går en kortare GDPR-repetition minst vartannat år.

© 2025 Styrelsekörkortet

AVSNITT 11

Checklista – använd direkt

Fyra checklistor att bocka av – grundarbete, datalagring, säkerhet och rättigheter.

Grundläggande GDPR-arbete

- GDPR-ansvarig utsedd i styrelsen
- Registerförteckning upprättad (imy.se)
- Integritetspolicy skriven och publicerad
- PUB-avtal tecknat med förvaltare och revisorer
- Gallringsrutin dokumenterad och inlagd i kalender

Register & datalagring

- Medlemsregister innehåller bara nödvändiga uppgifter
- Tidigare medlemmar gallrade ur aktivt register
- Protokoll arkiverade korrekt (10 år)
- Löneunderlag och anställningsavtal sparade 7 år
- Kameraövervakning – inspelningar raderas efter 72h

Säkerhet & åtkomst

- Unika lösenord till alla system med personuppgifter
- Tvåfaktorsautentisering aktiverad där möjligt
- Åtkomst begränsad till de som behöver uppgifterna
- Avgående ledamöter får åtkomst återkallad direkt
- Känslig data skickas aldrig i klartext via mejl

Rättigheter & incidenter

- Rutin för registerutdrag dokumenterad (svar inom 1 mån)
- Rutin för rättelse och radering dokumenterad
- Incidentplan upprättad (IMY-anmälan inom 72h)
- Incidentlogg tillgänglig för styrelsen
- Nya medlemmar informeras om integritetspolicyn

STYRELSEKÖRKORTET

Lär dig allt om GDPR och mycket mer.

Sveriges mest effektiva utbildning för förtroendevalda i bostadsrättsföreningar.

styrelsekorkortet.se

Kom igång idag.

Juridik · Ekonomi · Förvaltning · Teknik – samlat på ett ställe.

info@styrelsekorkortet.se

© 2025 Styrelsekörkortet